收支有度 | 安全自评报告

从容计划 · FinTechathon 2026 · 2026-11-01

参赛队伍：从容计划。材料日期：2026年11月1日。

本报告说明当前实现、风险控制与已知限制，对象为虚构账户和受控智能体演示系统，不代表第三方安全认证或真实银行接入。

01 权限分级与资金操作

纯查询和确定性计算按低风险处理；需要确认的资金与敏感业务操作展示具体对象及摘要，由用户独立确认或拒绝；高风险动作进入独立验证。用户确认与模型工具调用隔离，模型文字不能构成资金授权。

银行在最终提交时重查主体、金额、对象、版本、累计额度、有效期及锁定状态。验证凭证与单次操作摘要绑定并限时使用。未绑定验证器时高风险操作关闭，失败计数和锁定状态持久保存，重启不自动解锁。当前验证器使用测试身份，未接入银行实名、人脸或短信认证。

计划保存、目标选择、安排确认和付款授权是不同动作。正式代扣查询与撤销分别确认；撤销银行代扣授权不等于解除商户合同。已经成功的转账不能被承诺随意撤回。

02 事实、计算与输入安全

金额以整数分计算，日期和预测由确定性服务处理。回答绑定实际工具返回的字段、实体、时间及版本，关键金额和回执由宿主核验。对模糊范围或跨轮依据不足的请求，采用澄清或阻断；这些机制降低错误风险，但不保证理解任意自然语言。

工具按白名单暴露，写操作由业务层再次校验。银行备注、账单描述等外部内容按数据处理，不作为新的用户授权。验证秘密和模型密钥不进入提交源码，审计不记录验证秘密。使用合成数据演示，独立来源的历史数据不混入虚构账户余额。

03 审计、幂等与恢复

操作、任务、草案和方案保留身份与版本，调用尝试、派发事件、回执和失败状态分别持久记录。模型返回未知或连接中断时，先核对原操作，不通过换幂等键重复执行。已成功步骤与尚未执行步骤分开恢复。

跨库读取核对固定快照及版本；发生竞争更新则重新查询。银行状态与事件日志通过事务与幂等机制配合，但不宣称整个系统具有跨库原子性。记录存在歧义、回包缺失或生产者尚未结束时保持状态不确定，不把这种情况展示为成功。

04 隔离与运行限制

DSH采用受限工具和容器运行，宿主出口代理约束网络访问。工具白名单、容器网络限制和宿主代理属于不同控制层。文件访问、备注注入及网络隔离的完整组合场景仍需扩大验证，不能据当前样本宣称全面抗注入或容器逃逸安全认证。

AI调用有运行次数、服务商请求和时段约束；到限或停批后不自动重启。工具模式保留账本与计划能力，关闭聊天和自动AI解释；后台服务不可用时不得将待分析事件显示为已完成服务。测试预算与密钥由部署者独立配置。

05 验证覆盖与当前限制

本轮真实模型业务初测已执行21项，其中17项满足对应断言，4项出现业务理解、引用或提示完整性问题；其余11项初测与12项固定复测尚未执行。已测范围未观察到关键资金违规，该结论不外推到未测场景。主要问题包括明确账单期间的跨轮绑定、比较日期引用、代扣查询后的解释完整性，以及确认要求的文字披露。

连续目标故事在首步发生模型引用校验阻断，后续6步未执行；因此不能把分项测试、准确算值或人工计划操作等同于整条AI服务链已经验证。另有余额与消费对比分项证据，以及准确草案保存证据，但它们不替代上述连续旅程。

部分恢复业务断言已得到限定覆盖，运行器异常和归档缺口仍保留；部分审计异常链仍存在信息不完整。文件、网络与注入相关安全组合仅有部分覆盖。后续应优先完善跨轮请求绑定、异常审计与连续旅程，再扩大新环境及隔离测试。

06 交付与使用建议

公开源码排除密钥、个人日志及运行账本，提供依赖、部署说明和测试代码。部署者应使用独立数据目录，在模型、Docker及DSH准备完成后才启用AI；先以工具模式确认页面、账本和计划功能。对真实金融用途，必须另行完成银行接入、身份认证、权限隔离、安全测试与运行保障，本演示不直接用于真实资金办理。